

Handbuch fuer Einsteiger

Cyber Resilience Act verstaendlich erklaert

Fuer Maschinenbauer ohne Cybersecurity-Vorwissen

Was dieses Handbuch leistet

Begriffe, Beispiele und konkrete Hinweise fuer jeden Bereich in CRAwerk.

Vom ersten Produkt bis zur CRA-Akte, SBOM, Risiken und Konformitaetsabschluss.

Version 1.0 | Stand: 25. September 2026

Rechtsgrundlage: Verordnung (EU) 2024/2847 (Cyber Resilience Act)

So benutzen Sie dieses Handbuch

Sie muessen kein IT-Sicherheitsprofi sein, um mit CRAwerk zu arbeiten. Lesen Sie dieses **Handbuch beim**

ersten Durchlauf einmal von vorne bis hinten. Danach reicht es in der Regel, bei einem **offenen CRAwerk-**

Schritt das passende Kapitel nachzuschlagen.

- Teil A erklart den CRA und die wichtigsten Fachbegriffe in normaler Sprache.
- Teil B erklart die acht Bereiche der Maschinenakte und zeigt, was dort hineingehoert.
- Teil C fuehrt durch den gefuehrten CRA-Abschluss und die gesetzlichen Sonderfaelle.
- Teil D enthaelt ein vollstaendiges Beispiel fuer eine fiktive Maschine sowie eine Start-Checkliste.

Wichtiger Hinweis

CRAwerk organisiert, fuehrt und dokumentiert den Prozess. Die Software kann nicht pruefen, **ob eine**

technische Massnahme fachlich ausreichend ist, ob eine Risikobewertung inhaltlich richtig **ist oder ob eine**

konkrete Maschine rechtlich korrekt eingestuft wurde. Diese Verantwortung bleibt beim **Hersteller. Bei**

Zweifelsfaellen sollte fachkundige technische oder rechtliche Beratung einbezogen werden.

Inhalt

1. 1. Der Cyber Resilience Act in 10 Minuten
2. 2. Faellt unsere Maschine unter den CRA?
3. 3. Die wichtigsten Fristen
4. 4. Begriffe, die jeder Nutzer von CRAwerk kennen sollte
5. 5. So ist CRAwerk aufgebaut
6. 6. Grunddaten der Maschine
7. 7. Software, Firmware und Versionen
8. 8. Digitale Bauteile und Zulieferer
9. 9. Risiken und Aufgaben richtig erfassen
10. 10. Sicherheitsluecken und Updates
11. 11. Unterlagen und Nachweise
12. 12. Unterstuetzungszeitraum

13. 13. Gefuehrter CRA-Abschluss in sechs Schritten**14. 14. Die 22 Schutzanforderungen in normaler Sprache****15. 15. Technische Dokumentation und Nutzerinformationen****16. 16. Sicherheitsprozess und CVD****17. 17. Konformitaet, EU-Erklaerung und CE****18. 18. Sonderfaelle: Meldung, Nichtkonformitaet und Behoerde****19. 19. Beispiel: Verpackungsanlage VP-240****20. 20. Checkliste fuer den ersten Durchlauf****21. 21. Glossar****22. 22. Offizielle Quellen****CRAwerk Handbuch fuer
Einsteiger****1. Der Cyber Resilience Act in 10 Minuten****Was sich fuer Hersteller von vernetzten Maschinen aendert**

Der Cyber Resilience Act (CRA) ist die Verordnung (EU) 2024/2847. Er schafft EU-weite Cybersicherheitsanforderungen fuer Hardware- und Softwareprodukte mit digitalen Elementen, **die auf dem**

EU-Markt bereitgestellt werden. Dazu gehoeren Endprodukte ebenso wie separat in Verkehr **gebrachte**

Software- und Hardwarekomponenten. [1][2]

Fuer Maschinenbauer ist vor allem wichtig: Eine Maschine ist nicht nur wegen ihres **mechanischen Aufbaus**

zu betrachten. Sobald Steuerungen, Software, Firmware, Netzwerkschnittstellen, Fernwartung **oder andere**

digitale Funktionen zur Maschine gehoeren, kann der CRA relevant sein. Entscheidend ist **immer das**

konkrete Produkt, seine Zweckbestimmung, seine vorhersehbare Verwendung und der rechtliche Anwendungsbereich.

**Was der CRA vom Hersteller verlangt
Pflichtbereich In normaler Sprache**

Sicher entwickeln Cyberrisiken muessen schon bei Planung, Entwicklung und Herstellung beruecksichtigt werden.

Risiken bewerten Der Hersteller muss die Cyberrisiken des Produkts bewerten und die Bewertung dokumentieren und bei Bedarf aktualisieren.

Schwachstellen behandeln Bekannte Sicherheitsluecken und Schwachstellen in **eigenen und zugelieferten Komponenten muessen** waehrend des Supportzeitraums bearbeitet werden.

Updates bereitstellen Wenn Sicherheitsupdates noetig sind, muessen sie **sicher** und nachvollziehbar bereitgestellt werden.

Dokumentieren Technische Dokumentation, Nutzerinformationen, Konformitaetsnachweise und weitere Unterlagen muessen vorhanden sein.

Konformitaet nachweisen Vor dem Inverkehrbringen muss das passende Konformitaetsverfahren durchlaufen und die EU-Konformitaet erklaert werden.

Melden Aktiv ausgenutzte Schwachstellen und bestimmte schwere Sicherheitsvorfaelle unterliegen seit 11.09.2026 gesetzlichen Meldefristen.

Die Grundidee fuer CRAwerk

Sie bauen und kennen Ihre Maschine. CRAwerk soll Ihnen nicht beibringen, Jurist zu werden.

Die Anwendung

fuehrt Sie durch die Informationen, Entscheidungen und Nachweise, die fuer den CRA-Prozess **benoetigt** werden, und fuehrt daraus eine nachvollziehbare Maschinen- und CRA-Akte.

2. Faellt unsere Maschine unter den CRA?

Ein einfacher Vorcheck fuer Maschinenbauer

Der CRA gilt grundsaeztlich fuer Hardware- und Softwareprodukte mit digitalen Elementen, die **auf dem** Unionsmarkt bereitgestellt werden. Nach der Zusammenfassung der EU-Kommission fallen **Produkte in den**

CRAwerk Handbuch fuer Einsteiger

Anwendungsbereich, wenn ihre Zweckbestimmung oder vernünftigerweise vorhersehbare Verwendung **eine**

direkte oder indirekte logische oder physische Datenverbindung zu einem Geraet oder Netzwerk **umfasst. [2]**

Typische Hinweise bei einer Maschine

Frage Wenn Ja, ist der CRA oft relevant

Hat die Maschine eine SPS, CNC, Robotik- oder andere Die Steuerung enthaelt Software bzw.

Firmware

und ist

programmierbare Steuerung? ein wichtiger digitaler Bestandteil.

Gibt es ein HMI oder einen Industrie-PC? Betriebssystem, Runtime, Applikation und Kommunikationsschnittstellen sind digitale Elemente.

Ist Ethernet, WLAN, Feldbus, OPC UA, MQTT oder eine Netzwerk- und Busschnittstellen koennen

Angriffswege

andere Datenverbindung vorhanden? und Sicherheitsanforderungen erzeugen.

Gibt es Fernwartung oder Cloud-/Portalzugriff? Fernzugriff, VPN, Gateways und Remote-Dienste gehoeren in die Sicherheitsbetrachtung.

Werden Updates ueber USB, Netzwerk oder Service-Tool Der Updateweg muss gegen Manipulation **und**

eingespielt? Fehlbedienung betrachtet werden.

Wird die Maschine unter Ihrem Namen oder Ihrer Marke Dann sind Sie im CRA-Kontext

regelmaessig der

verkauft? Hersteller des Gesamtprodukts.

Nicht jede Maschine ist automatisch gleich zu behandeln

Es gibt Ausnahmen und Abgrenzungen zu anderen EU-Rechtsakten. Auch die Frage, ob ein Produkt **als**

Standardprodukt, wichtiges Produkt der Klasse I oder II oder als kritisches Produkt gilt,

haengt von der

konkreten Kernfunktion ab. CRAwerk hilft bei der Dokumentation, ersetzt diese rechtliche

Einordnung aber

nicht.

Faustregel fuer die Praxis

Eine rein mechanische Sonderkonstruktion ohne digitales Element ist etwas anderes als eine

automatisierte

Anlage mit SPS, HMI, Netzwerk und Fernwartung. Bei modernen Maschinen mit programmierbarer

Steuerung

sollte der CRA deshalb frueh im Projekt geprueft werden, statt erst kurz vor der Auslieferung.

3. Die wichtigsten Fristen

Welche CRA-Regeln wann gelten

Datum Bedeutung

10.12.2024 Der CRA ist in Kraft getreten.

11.06.2026 Regeln zur Notifizierung von Konformitaetsbewertungsstellen in Kapitel IV gelten.

11.09.2026 Die gesetzlichen Meldepflichten aus Artikel 14 fuer aktiv ausgenutzte Schwachstellen und schwere Sicherheitsvorfaelle gelten.

11.12.2027 Die Verordnung gilt im Wesentlichen vollstaendig. Ab dann muessen neue Produkte im Anwendungsbereich die CRA-Anforderungen erfuellen.

CRAwerk Handbuch fuer Einsteiger

Produkte, die bereits vor dem 11.12.2027 in Verkehr gebracht wurden, werden nicht pauschal **nachtraeglich**

wie neue Produkte behandelt. Die EU-Kommission weist jedoch darauf hin, dass die **Meldepflichten auch fuer**

bereits auf dem Markt befindliche Produkte gelten und dass bestehende Produkte ab dem **11.12.2027 bei**

wesentlichen Aenderungen relevant werden koennen. [2][3]

Stand dieses Handbuchs: 25.09.2026

Die Meldepflichten laufen bereits. Die vollstaendige Anwendung des CRA folgt am 11.12.2027. **Deshalb ist**

jetzt

der richtige Zeitpunkt, Prozesse, Produktakten und Verantwortlichkeiten aufzubauen.

4. Begriffe, die jeder Nutzer von CRAwerk

kennen sollte

Begriff Einfach erklart Beispiel im Maschinenbau

**Software Programme und digitale Logik, die auf HMI-Applikation, PC-Software, SPS-
einem Rechner oder Controller Programm, Service-Tool**

ausgefuehrt werden.

Firmware Software, die sehr nah an der Hardware SPS-Firmware, Gateway-Firmware,

arbeitet und meist dauerhaft im Geraet Antriebs-Firmware, Bootloader gespeichert ist.

Betriebssystem Grundsoftware, auf der weitere Windows IoT, Linux auf **einem Industrie-**

Programme laufen. PC

Komponente Ein digital relevantes Bauteil oder SPS, HMI, Router, Gateway, **Bibliothek**

Softwareelement innerhalb des

Gesamtprodukts.

Schwachstelle Eine konkrete technische oder Standardpasswort, verwundbare

organisatorische Schwaeche, die Bibliothek, unsigniertes Update ausgenutzt werden kann.

CVE Eine oeffentliche Kennung fuer eine CVE-20xx-12345 eines Routers

bekannte Schwachstelle. Nicht jede reale Schwachstelle hat sofort eine CVE.

Exploit Eine Methode oder ein Programm, das Code, der ueber eine Luecke **eine Schwachstelle ausnutzt. unbefugten Zugriff ermoeeglicht**

Patch / Sicherheitsupdate Aenderung, die eine Schwachstelle oder Firmware 3.2.4 behebt eine **bekannte**

ein Sicherheitsproblem behebt. Luecke

SBOM Software Bill of Materials, also eine Liste aus HMI-App, Bibliotheken, maschinenlesbare Software-Stueckliste. Runtime und Versionen

CVD Coordinated Vulnerability Disclosure, security@firma.de, Bestaetigung,

also der geregelte Umgang mit extern Bewertung, Patch, Veroeffentlichung gemeldeten Schwachstellen.

Supportzeitraum Zeitraum, in dem der Hersteller Unterstuetzung bis 12/2034 **Schwachstellen behandelt und**

Sicherheitsupdates bereitstellt.

Nachweis Dokument oder Referenz, mit der eine Testbericht, Zeichnung,
Ticket, Release

5

Aussage belegt werden kann. Note, DMS-ID

**CRAwerk Handbuch fuer
Einsteiger****Software oder Firmware - was ist der Unterschied?****Software Firmware**

Oft leichter austauschbare Programme oder Geraetenae Software:

SPS-Betriebssystem/Firmware,

Applikationen: HMI-Projekt, Windows-Anwendung, SPS- Router-Firmware,

Antriebsregler-Firmware,**Bootloader**

Projekt, Datenbankdienst, Bibliotheken. oder Embedded-Software im Geraet.

Fuer CRAwerk gilt

Wenn eine Software oder Firmware die Funktion oder Sicherheit der Maschine beeinflussen

kann, sollte sie

nachvollziehbar erfasst werden. Sie muessen nicht jede interne Zeile Code einzeln eintragen.

Wichtig sind

identifizierbare Komponenten und Versionen.

5. So ist CRAwerk aufgebaut**Maschinenakte zuerst, CRA-Abschluss danach**

CRAwerk arbeitet mit einer zentralen Maschinenakte. Alles, was Sie dort bereits erfassen,

wird spaeter fuer

den CRA-Abschluss weiterverwendet. Dadurch sollen dieselben Informationen nicht mehrfach

gepflegt

werden.

Maschinenakte Wozu der Bereich dient**1. Grunddaten Produkt eindeutig identifizieren und
Verantwortlichkeit**

festhalten.

**2. Software & Versionen Software, Firmware und Versionen erfassen und
daraus**

die SBOM vorbereiten.

3. Zulieferer & Bauteile Digitale Komponenten und Hersteller nachvollziehbar
machen.

4. Risiken & Aufgaben Cyberrisiken mit Massnahme, Verantwortlichem und Status bearbeiten.

5. Sicherheitsluecken & Updates Konkrete Schwachstellen und Behebungen verfolgen.

6. Unterlagen & Nachweise Vorhandene Belege der Maschine zuordnen.

7. Unterstuetzungszeitraum Festlegen, wie lange Sicherheitsbetreuung erfolgt und wie
das Ende kommuniziert wird.

8. CRA-Abschluss Einstufung, Schutzpruefung, technische Dokumentation,
EU-Erklaerung und CE zusammenfuehren.

CRAwerk Handbuch fuer Einsteiger

Der normale Arbeitsablauf

1. Maschine anlegen und Grunddaten erfassen.

2. Software, Firmware und digitale Bauteile vervollstaendigen.

3. Cyberrisiken pruefen und offene Aufgaben bearbeiten.

4. Internen Prozess fuer Sicherheitsprobleme festlegen.

5. Unterlagen und Supportzeitraum dokumentieren.

6. Den gefuehrten CRA-Abschluss oeffnen und nur die noch fehlenden Angaben bearbeiten.

7. Kurzakten, Vollakte, SBOM, Nutzerinformationen und EU-Erklaerung erzeugen.

6. Grunddaten der Maschine

Die Grunddaten sind keine Formalitaet. Spaeter muessen Dokumente, Risiken,
Softwareversionen, Support
und die EU-Konformitaetserklaerung eindeutig zum richtigen Produkt passen.

Feld Was hinein gehoert Beispiel

Name der Maschine Verstaendliche Produkt- oder Verpackungsanlage VP-240

Maschinenbezeichnung.

Modell / Baureihe Baureihe, Typ oder Modell, falls VP-240
vorhanden.

Produktnummer Interne Artikel-, Maschinen- oder VP240-2026-017
Produktnummer.

Verantwortlich Interne Rolle oder Person, die die Produktmanagement / Max
Akte fachlich betreut. Mustermann

Software/Firmware vorhanden Ja, sobald programmierbare oder Ja
eingebettete Software zur Maschine
gehört.

Datenverbindung Ja, wenn direkte oder indirekte Ethernet + Fernwartung
Verbindungen zu Geraeten oder
Netzen vorgesehen sind.

Guter Eintrag

Name und Produktnummer sollten so eindeutig sein, dass auch in zwei Jahren noch klar ist,
fuer welche
konkrete Produktvariante die Akte gilt.

7. Software, Firmware und Versionen

Was in die Softwareliste gehoert

Dieser Bereich beantwortet eine einfache Frage: Welche Software- und Firmwarestaende
gehoren zu genau
dieser Maschine? Nur wenn diese Zuordnung sauber ist, kann spaeter bewertet werden, ob eine
bekannte
Schwachstelle das Produkt betrifft.

Typische Eintraege

- SPS-Programm bzw. Steuerungssoftware und der zugehoerige freigegebene Stand.
 - SPS- oder Controller-Firmware, wenn Version und Herstellerstand fuer Sicherheit oder
- Kompatibilitaet relevant**

sind.
- HMI-Runtime und HMI-Applikation.

CRAwerk Handbuch fuer Einsteiger

- Betriebssystem eines Industrie-PCs oder Embedded-Rechners.
- Maschinenapplikation, Service-Software oder lokaler Webserver.
- Gateway-, Router- oder Fernwartungs-Firmware.
- Wichtige Bibliotheken, Frameworks und Open-Source-Abhaengigkeiten, soweit bekannt und fuer

die SBOM

relevant.

Was Sie nicht tun muessen

Sie muessen nicht jede SPS-Variable, jede Quellcodedatei oder jedes Unterprogramm als **eigenen**

Softwareeintrag anlegen. Ziel ist eine belastbare Versions- und Komponentenubersicht, keine Kopie des

gesamten Quellcodes.

Zu wenig Besser

"SPS" "Steuerungsprogramm VP-240 | Release 2.7.4 |
freigegeben 18.09.2026"

"HMI" "HMI Runtime | Version 5.4.2 | Hersteller XY"

"Router" "Remote Gateway RG-100 | Firmware 4.8.1 |
Hersteller
ABC"

"Linux" "Embedded Linux Distribution | Release 2026.2 |
Image-ID
img-240-17"

Was bedeutet purl?

Eine Package URL (purl) ist eine standardisierte Kennung fuer Softwarepakete. Sie ist **besonders bei**

Bibliotheken und Open-Source-Komponenten hilfreich. Wenn Sie keine verlaessliche purl **kennen, erfinden**

Sie keine. Lassen Sie das Feld leer und pflegen Sie stattdessen Name, Version und Hersteller sauber.

Top-Level und transitive Abhaengigkeiten

Eine Top-Level-Komponente wird direkt von Ihrem Produkt verwendet. Eine transitive **Abhaengigkeit wird von**

einer anderen Softwarekomponente mitgebracht. CRAwerk kann diese Unterscheidung fuer die **SBOM**

nutzen. Fuer den Einstieg ist wichtiger, dass die Liste nachvollziehbar und nicht erfunden ist.

SBOM in CRAwerk

Aus der gepflegten Softwareliste kann CRAwerk eine maschinenlesbare CycloneDX-SBOM erzeugen.

Die

Qualitaet dieser SBOM ist nur so gut wie die erfassten Komponenten und Versionen.

8. Digitale Bauteile und Zulieferer

Hier geht es nicht um jede Schraube und jedes mechanische Kaufteil. Erfasst werden vor allem Komponenten, deren digitale Funktion, Firmware oder Kommunikation die Cybersicherheit der **Maschine**

beeinflussen kann.

Typisch erfassen Nur bei Relevanz / eher nicht

SPS, HMI, Industrie-PC, Router, Gateway, Switch, Mechanische Lager, Gehaeuse, Standardkabel, **rein**

vernetzter Antrieb, Smart Sensor, Kamera, Funkmodul passive Bauteile ohne digitale Funktion

Hersteller, Typ/Modell, Hardware- oder Firmwarestand, Unklare Sammelbegriffe wie **"Elektronik" ohne Typ**

oder

vorhandene Sicherheitsunterlagen Hersteller

**CRAwerk Handbuch fuer
Einsteiger****Warum dieser Bereich wichtig ist**

Wenn ein Zulieferer eine Sicherheitsluecke meldet, muessen Sie schnell beantworten koennen:

Welche

Produkte enthalten dieses Bauteil und welche Version ist verbaut? Eine gepflegte

Komponentenliste spart im

Ernstfall viel Sucharbeit.

Praxisbeispiel

Ein Routerhersteller meldet eine kritische Schwachstelle fuer Firmware 4.7.x. In CRAwerk

sehen Sie sofort,

ob

die VP-240 noch Firmware 4.7.9 verwendet oder bereits auf 4.8.1 aktualisiert wurde.

9. Risiken und Aufgaben richtig erfassen**Was bei "Risiko" wirklich hineingehoert**

Der Risikobereich ist nicht die klassische Maschinenrisikobeurteilung fuer mechanische

Gefahren. Er dient

hier dazu, Cyberrisiken und daraus entstehende Aufgaben nachvollziehbar zu machen. Der CRA **verlangt**

eine Cybersicherheitsrisikobewertung, die in Planung, Entwicklung, Herstellung, Lieferung

und Wartung

beruecksichtigt wird. [1][2]

Ein guter Risikoeintrag beantwortet vier Fragen

1. Was kann passieren oder ausgenutzt werden?
2. Welche Auswirkung haette das auf Maschine, Daten oder Nutzer?
3. Welche Massnahme reduziert oder beseitigt das Risiko?
4. Wer ist verantwortlich und ist die Massnahme erledigt?

Schlechtes Beispiel Gutes Beispiel

"Hackerangriff moeglich" "Fernwartung nutzt einen gemeinsam verwendeten Service-

Account. Bei Weitergabe des Passworts ist unbefugter Zugriff auf die Steuerung moeglich. Massnahme: personenbezogene Konten, Rollen und MFA einfuehren. Verantwortlich: Softwareentwicklung."

"USB unsicher" "Firmware kann ueber Service-USB ohne Signaturpruefung

eingespielt werden. Manipulierte Firmware waere moeglich. Massnahme: Signaturpruefung im Bootloader und freigegebene Updatepakete."

Typische Cyberrisiken bei Maschinen**Thema Beispiel**

Zugriff Standardpasswoerter, gemeinsame Servicekonten, fehlende Rollen, ungeschuetzte Fernwartung

Netzwerk Unnoetige offene Ports, unverschlusselte Protokolle, direkte Internetfreigabe, fehlende Segmentierung

Updates Unsignierte Firmware, Updatepakete ohne Integritaetspruefung, kein Rollback oder kein nachvollziehbarer Releaseprozess

Daten Unverschlusselte Zugangsdaten, sensible Daten in

Logfiles, fehlende sichere Loeschung

CRAwerk Handbuch fuer Einsteiger

Thema Beispiel

Verfuegbarkeit Kommunikationsschnittstellen koennen die Steuerung

ueberlasten oder wesentliche Funktionen blockieren

Zulieferer Abhaengigkeit von Komponenten ohne Sicherheitsupdates oder mit abgekundigtem Support

Protokollierung Sicherheitsrelevante Anmeldungen oder Aenderungen

sind spaeter nicht nachvollziehbar

Wie whle ich Niedrig, Mittel oder Hoch?

CRAwerk verwendet die Stufe als praktische interne Priorisierung, nicht als gesetzlich
vorgeschriebenes

Rechenmodell. Bewerten Sie gemeinsam die moegliche Auswirkung und wie realistisch eine
Ausnutzung ist.

Ein fern erreichbarer Zugang mit schwachem Passwort ist meist hoeher zu priorisieren als
eine nur lokal

erreichbare Servicefunktion in einem geschuetzten Schaltschrank.

Stufe Praktische Orientierung

Niedrig Begrenzte Auswirkung und schwer auszunutzen;

Massnahme kann geplant bearbeitet werden.

Mittel Relevante Auswirkung oder realistische Ausnutzung; klare

Massnahme und Termin erforderlich.

Hoch Schwere Auswirkung, einfache/ferne Ausnutzung oder

kritische Sicherheitsfunktion betroffen; vorrangig

bearbeiten.

Wichtig

Ein Eintrag "kein Risiko" ist kein Ersatz fuer eine Pruefung. Wenn keine offenen Risiken
verbleiben, kann
die

Risikopruefung abgeschlossen werden. Dahinter sollte aber eine nachvollziehbare Bewertung stehen.

10. Sicherheitsluecken und Updates

Der Unterschied zwischen Risiko und konkreter Schwachstelle

Risiko Sicherheitsproblem / Schwachstelle

Ein moegliches Szenario. Beispiel: Fernwartung koennte Ein konkreter Sachverhalt. Beispiel:

Der

verbaute Router

bei schwachen Zugangsdaten missbraucht werden. hat eine bekannte Schwachstelle in Firmware
4.7.9.

Sobald eine konkrete Schwachstelle oder ein Sicherheitsproblem bekannt ist, sollte es im
Bereich

"Sicherheitsluecken & Updates" verfolgt werden. Der Eintrag bleibt offen, bis Bewertung,

Behebung und

Nachweis sauber dokumentiert sind.

Feld Was hinein gehoert

Bezeichnung Kurzer, eindeutiger Titel des Problems.

Betroffen Produkt, Bauteil, Software und Version.

Schweregrad Interne Bewertung Niedrig/Mittel/Hoch/Kritisch

bzw.

spaetere fachliche Bewertung.

CRAwerk Handbuch

fuer Einsteiger

Feld Was hinein gehoert

Bewertung Warum ist die Maschine betroffen und welche

Auswirkung

ist zu erwarten?

Massnahme Patch, Konfigurationsaenderung, Workaround,

Austausch

oder andere Behebung.

Patch-/Zielversion Version, in der das Problem behoben ist.

Behoben am Datum der umgesetzten Behebung.

Sicherheitshinweis / Nachweis Veroeffentlichter Hinweis, DMS-ID, Release

Note oder

begründete Dokumentation einer späteren

Veröffentlichung.

Nicht vorschnell schliessen

CRAwerk verlangt vor dem Abschluss eines Sicherheitsproblems einen bewerteten Schweregrad, **ein**

Behebungsdatum und einen Veröffentlichungs-/Nachweisverweis. Damit bleibt nachvollziehbar, **was wirklich**

passiert ist.

11. Unterlagen und Nachweise**Was als Beleg zählt**

CRAwerk soll keine zweite Dateiablage erzwingen. Im Bereich "Unterlagen & Nachweise" ordnen **Sie**

vorhandene Dokumente der Maschine zu. Die eigentliche Datei kann weiterhin in Ihrem DMS, **Netzlaufwerk,**

PLM oder Projektordner liegen. Entscheidend ist ein eindeutiger Verweis.

Guter Nachweis Beispiel

Testbericht Security-Test VP-240, Bericht SEC-2026-014

Architektur-/Netzplan Netzwerkplan NW-VP240-03, Revision C

**Lieferantenhinweis Security Advisory des Gateway-Herstellers,
Referenz**

SA-2026-88

**Release Note Firmware Release 2.7.4, Aenderung "signed
update
verification"**

Ticket / Aufgabe Jira SEC-412 oder internes Q-Ticket 8821

Pruefprotokoll Reviewprotokoll Fernwartung 18.09.2026

**Benutzerinformation Betriebsanleitung Kapitel "Sichere
Inbetriebnahme"**

**Konformitaetsunterlage Unterzeichnete EU-Konformitaetserklaerung,
DMS-ID
DOC-4711**

So benennen Sie Nachweise sinnvoll

Ein guter Verweis ist fuer eine andere Person auffindbar. "Siehe Ordner" ist schwach. "DMS:

SEC-2026-014,

Security-Test VP-240, Rev. B" ist belastbar.

12. Unterstuetzungszeitraum

Wie lange Sicherheitsluecken betreut werden

Der CRA verlangt, dass Hersteller einen Supportzeitraum festlegen, der die erwartete

Nutzungsdauer des

Produkts widerspiegelt. Grundsatzlich betraegt dieser Zeitraum mindestens fuenf Jahre. Wird

das Produkt

voraussichtlich kuerzer als fuenf Jahre genutzt, darf der Zeitraum der erwarteten

Nutzungsdauer entsprechen.

Die Kriterien fuer die Festlegung muessen dokumentiert werden. [1]

Maschinenbauer aufgepasst

Bei einer Maschine mit erwarteter Nutzungsdauer von zehn oder fuenfzehn Jahren ist "fuenf

Jahre, weil das

Minimum fuenf Jahre ist" keine gute Begrueendung. Der CRA verlangt, dass die erwartete

Nutzungsdauer und

weitere relevante Faktoren betrachtet werden.

CRAwerk-Feld Beispiel

Beginn 01.01.2027

Geplantes Ende 31.12.2034

Verantwortlich Produktmanagement

Begrueendung Erwartete Nutzungsdauer ca. 8 Jahre;

Kernkomponenten

werden vom Zulieferer mindestens bis 2034 unterstuetzt.

Wo beim Kauf sichtbar? Angebot, Auftragsbestaetigung und Produktseite

Kann das Produkt das Supportende technisch melden? Ja - Hinweis im HMI und Kundenportal

Nachweis nach Supportende Mailing-ID, HMI-Release oder Portalnachweis

Das Enddatum des Supportzeitraums muss beim Kauf klar und leicht zugaenglich angegeben

werden,

mindestens mit Monat und Jahr. Wenn es technisch machbar ist, sollen Nutzer beim Erreichen

des

Supportendes eine Mitteilung erhalten. [1]

13. Gefuehrter CRA-Abschluss in sechs

Schritten

Nach der Maschinenakte oeffnen Sie den CRA-Abschluss. Dort zeigt CRAwerk nur sechs

Arbeitsschritte und

immer den naechsten offenen Schritt. Die juristische Zuordnung bleibt im Hintergrund

sichtbar, wenn sie

gebraucht wird.

Schritt Was Sie tun

1. Produkt einordnen Produktklasse festlegen, Kernfunktion beschreiben,

Normenabdeckung und Konformitaetsweg dokumentieren.

2. Schutz pruefen Die 22 grundlegenden Anforderungen in fuenf

verstaendlichen Themenbloecken bewerten.

3. Maschine beschreiben Zweck, Einsatzumgebung, Architektur, Nachweise und

Nutzerinformationen vervollstaendigen.

4. Sicherheitsprozess Meldekontakt, CVD, Updateverteilung und Umgang mit

Drittkomponenten beschreiben.

CRAwerk Handbuch fuer Einsteiger

Schritt Was Sie tun

5. Konformitaet CE-Status und EU-Konformitaetserklaerung

abschliessen.

6. Akte pruefen CRAwerk zeigt, welche Pflichtbereiche noch

offen sind.

Schritt 1: Produkt einordnen

Die meisten Produkte im Anwendungsbereich sind Standardprodukte. Bestimmte Kernfunktionen

koennen

jedoch unter die Listen wichtiger Produkte der Klasse I oder II oder kritischer Produkte

fallen. Die

technischen

Beschreibungen dieser Kategorien wurden durch die Durchfuehrungsverordnung (EU) 2025/2392

konkretisiert. [5]

Einstufung Bedeutung fuer CRAwerk

Standardprodukt Nicht als wichtiges oder kritisches Produkt

eingestuft.

Modul A kann grundsatzlich ein moeglicher Konformitaetsweg sein.

Wichtig - Klasse I Bei vollstaendiger Abdeckung ueber passende Normen

kann Modul A in Betracht kommen; sonst wird eine externe Bewertung relevant.

Wichtig - Klasse II Externe Konformitaetsbewertung bzw. geeignete

Zertifizierung wird relevant.

Kritisch Besonders sensible Produktkategorien mit strengeren Konformitaetswegen.

Nicht raten

Die Einstufung darf nicht aus dem Bauch heraus erfolgen. Pruefen Sie die aktuelle Fassung **von Anhang III und**

IV sowie die technischen Beschreibungen. CRAwerk speichert Ihre Entscheidung und die **Begruendung, trifft**

sie aber nicht rechtsverbindlich fuer Sie.

14. Die 22 Schutzanforderungen in

normaler Sprache

Was die fuenf Themenbloecke in CRAwerk meinen

Anhang I des CRA enthaelt die grundlegenden Cybersicherheitsanforderungen. CRAwerk zeigt sie als

alltagstaugliche Fragen. Fuer jeden Punkt gibt es "Noch offen", "Ja - erfuellt" oder "Trifft **nicht zu" sowie**

Platz

fuer kurze Begruendung und Nachweis.

A. Zugriff & Grundeinstellungen

Frage in CRAwerk Woran Sie denken sollten

Startet die Maschine mit sicheren Grundeinstellungen? Keine unsicheren Standardpasswoerter; **sichere**

Werkseinstellungen; sinnvolle Ruecksetzung.

Ist unbefugter Zugriff ausreichend verhindert? Authentifizierung, Rollen, Rechte, Schutz

von

Servicezugaengen und Fernwartung.

CRAwerk

Handbuch fuer Einsteiger

Frage in CRAwerk Woran Sie denken sollten

Sind Schnittstellen und Angriffsflächen auf das Noetige Unnoetige Ports, Dienste und

Schnittstellen

deaktivieren oder

begrenzt? schuetzen.

Werden Folgen eines erfolgreichen Angriffs begrenzt? Segmentierung, Rechtebegrenzung,

sichere

Wiederanlauf-

oder Schutzmechanismen.

Koennen wichtige Sicherheitereignisse nachvollzogen Protokollierung sicherheitsrelevanter

Anmeldungen,

werden? Aenderungen und Ereignisse.

B. Daten & Kommunikation

Frage in CRAwerk Woran Sie denken sollten

Sind vertrauliche Daten geschuetzt? Schutz gespeicherter und uebertragener

sensibler Daten.

Sind Daten, Befehle und Einstellungen gegen Manipulation Integritaetspruefung, Signaturen,

geschuetzte Konfiguration,

geschuetzt? sichere Kommunikation.

Verarbeitet die Maschine nur Daten, die sie wirklich braucht? Datenminimierung und

Vermeidung unnoetiger

personenbezogener oder technischer Daten.

Koennen Daten sicher geloescht und uebertragen werden? Sichere Loeschung bei

Ausserbetriebnahme und

geschuetzte

Datenuebertragung.

C. Betrieb & Widerstandsfahigkeit

Frage in CRAwerk Woran Sie denken sollten

Passt das Sicherheitsniveau zum Risiko? Schutzmassnahmen muessen zum Produkt,

Einsatz und

moeglichen Schaden passen.

Bleiben wichtige Funktionen bei Angriffen moeglichst Robustheit gegen Stoerungen,

Ueberlastung

und

verfuegbar? Sicherheitsvorfaelle.

Kann die Maschine andere Geraete oder Netze unnoetig Verhindern, dass das Produkt selbst zur

Stoerquelle oder

beeintraechtigen? Angriffsplattform wird.

D. Software, Updates & Komponenten

Frage in CRAwerk Woran Sie denken sollten

Sind keine bekannten ausnutzbaren Schwachstellen mehr Bekannte relevante Luecken vor

Inverkehrbringen bewerten

offen? und beheben.

Koennen Sicherheitsupdates sicher eingespielt werden? Updateweg, Authentizitaet, Integritaet

und

sichere Installation.

Sind Softwarekomponenten und Abhaengigkeiten Softwareliste und SBOM mindestens fuer

relevante

nachvollziehbar? Abhaengigkeiten.

Werden gefundene Schwachstellen zuegig behoben? Risikoabhaengige Priorisierung, Patch oder

andere

Korrekturmassnahme.

Werden Sicherheitsupdates sicher verteilt? Manipulationsgeschuetzte Bereitstellung und

eindeutige

14

Versionen.

Werden Sicherheitsupdates rechtzeitig und verstaendlich Kunden erhalten Update und klare

Hinweise zu

notwendigen

bereitgestellt? Massnahmen.

CRAwerk

Handbuch fuer Einsteiger

E. Pruefen & Schwachstellen bearbeiten

Frage in CRAwerk Woran Sie denken sollten

Wird die Produktsicherheit regelmaessig geprueft? Security-Tests, Reviews oder andere

geeignete

Pruefungen.

Werden Kunden ueber behobene Schwachstellen informiert? Sicherheitshinweis mit betroffenen

Versionen,

Schweregrad

und Behebung.

Gibt es einen festen Ablauf fuer gemeldete Schwachstellen? CVD-Prozess fuer Eingang,

Bestaetigung,

Bewertung,

Behebung und Veroeffentlichung.

Gibt es eine erreichbare Stelle fuer Sicherheitsmeldungen? Leicht auffindbarer Kontakt,

nicht

ausschliesslich

automatisierte Kommunikation.

Wann darf ich "Trifft nicht zu" waehlen?

Nur wenn die Anforderung fuer das konkrete Produkt wirklich nicht anwendbar ist. Dann

braucht CRAwerk

eine kurze Begrueendung. Beispiel: Wenn ein Produkt keine Benutzerdaten speichert und keine

entsprechende

Funktion hat, kann ein spezieller Teil einer Datenloeschungsanforderung nicht anwendbar

sein. "Trifft nicht

zu" darf nicht verwendet werden, nur weil ein Punkt unbequem oder noch ungeklaert ist.

15. Technische Dokumentation und

Nutzerinformationen

Die technische Dokumentation muss erklaren, wie der Hersteller die CRA-Anforderungen

einhaelt, und

mindestens die Inhalte aus Anhang VII enthalten. Sie muss vor dem Inverkehrbringen erstellt

und waehrend

des Supportzeitraums bei Bedarf aktualisiert werden. [1]

Was CRAwerk in Schritt 3 abfragt

Themenblock Was gemeint ist

Produkt & Einsatz Zweckbestimmung, Einsatzumgebung, digitale

Kernfunktionen und vorhersehbare Fehlanwendung.

Aufbau & Nachweise Architektur, Zeichnungen, Aenderungsprozess,

Normen,

Testberichte und Aufbewahrung.

Informationen fuer Kunden Sichere Inbetriebnahme, Updates, Aenderungen,

Ausserbetriebnahme, Integratorhinweise und Support.

Informationen nach Anhang II

Produkte muessen von klaren Nutzerinformationen begleitet werden. Dazu gehoeren unter **anderem**

Herstellerkontakt, Schwachstellen-Kontaktstelle, eindeutige Produktidentifikation, Zweck und **Sicherheitsumgebung, bekannte oder vorhersehbare Cyberrisiken, Supportart und Supportende sowie**

Anweisungen fuer sichere Inbetriebnahme, Updates und Ausserbetriebnahme. [1]

CRAwerk-Ausgabe

CRAwerk kann aus den hinterlegten Angaben ein druckbares Dokument "Nutzerinformationen nach **Anhang II**"

erzeugen. Pruefen Sie es vor der Freigabe wie jede andere technische Kundenunterlage.

CRAwerk Handbuch fuer Einsteiger

16. Sicherheitsprozess und CVD

Was Ihr Unternehmen festlegen sollte

Der CRA verlangt nicht nur ein sicheres Produkt, sondern auch einen belastbaren Prozess fuer Schwachstellen. Eine Sicherheitsmeldung darf nicht davon abhaengen, ob zufaellig gerade die **richtige**

Person im Haus ist.

CRAwerk-Feld Inhalt

Kontaktstelle E-Mail oder Meldeformular plus direkte

Kommunikationsmoeglichkeit, z. B. security@firma.de.

CVD-Prozess Wie Eingang bestaetigt, Betroffenheit geprueft, **Schwere**

bewertet, Massnahme geplant und Veroeffentlichung

koordiniert wird.

Oeffentliche Fundstelle Webseite oder Dokument, auf dem der Meldeweg **fuer**

Externe leicht auffindbar ist.

Sichere Updateverteilung Wie Updates signiert, bereitgestellt, versioniert und

Kunden informiert werden.

Drittkomponenten Wie Zuliefererinformationen verfolgt werden und **wie Sie**

den Hersteller/Maintainer bei gefundenen Luecken

einbeziehen.

Ein einfacher CVD-Ablauf fuer ein kleines Unternehmen

- 1. Meldung ueber zentrale Kontaktstelle annehmen und Eingang bestaetigen.**
- 2. Betroffenes Produkt, Version und Komponente identifizieren.**
- 3. Schweregrad, Auswirkung und moegliche Ausnutzung bewerten.**
- 4. Korrekturmassnahme, Patch oder Workaround festlegen.**
- 5. Betroffene Kunden und gegebenenfalls Zulieferer koordinieren.**
- 6. Sicherheitshinweis und Update bereitstellen, wenn dies erforderlich ist.**
- 7. Vorgang mit Datum, Patchversion und Nachweis abschliessen.**

17. Konformitaet, EU-Erklaerung und CE

Der CRA ist EU-Harmonisierungsrecht. Wenn die Konformitaet nach dem anwendbaren Verfahren nachgewiesen wurde, stellt der Hersteller die EU-Konformitaetserklaerung aus und bringt die **CE-**

Kennzeichnung entsprechend den geltenden Regeln an. [1][2]

Begriff Was CRAwerk dokumentiert

Konformitaetsweg Modul A, B+C, Modul H oder anwendbare europaeische

Cybersicherheitszertifizierung.

Notifizierte Stelle Nur wenn der gewaehlte Weg eine externe Stelle einbezieht.

CE-Status Ob die CE-Kennzeichnung angebracht ist und wo sie sich

befindet.

EU-Konformitaetserklaerung Status, Ort, Datum, Unterzeichner, Funktion und **Ablage**

der unterzeichneten Fassung.

CRAwerk Handbuch fuer Einsteiger

Wichtig

Eine in CRAwerk erzeugte Erklaerung ist eine Dokumentvorlage aus Ihren Angaben. Erst die vom verantwortlichen Hersteller gepruefte und unterzeichnete Fassung ist der relevante Nachweis.

18. Sonderfaelle: Meldung,

Nichtkonformitaet und Behörde

Diese Bereiche werden nur geoeffnet, wenn etwas passiert

CRAwerk blendet diese Bereiche im normalen Ablauf aus. Sie werden erst benoetigt, wenn ein **Sicherheitsvorfall, eine Nichtkonformitaet oder eine Anfrage der Marktueberwachung eintritt.**

A. Aktiv ausgenutzte Schwachstelle oder schwerer Sicherheitsvorfall

Seit 11.09.2026 gelten die CRA-Meldepflichten aus Artikel 14. Bei einer aktiv ausgenutzten **Schwachstelle**

und bei einem schweren Sicherheitsvorfall gelten gestufte Meldungen. [1][3]

Vorgang Frist / Inhalt

Fruehwarnung Unverzueglich, spaetestens innerhalb von 24 Stunden

nach Kenntnis.

Weitere Meldung Unverzueglich, spaetestens innerhalb von 72 Stunden

nach Kenntnis; mit Produkt, Art, Bewertung und

Massnahmen soweit verfuegbar.

Abschluss bei aktiv ausgenutzter Schwachstelle Spaetestens 14 Tage nachdem eine Korrektur-**oder**

Risikominderungsmassnahme verfuegbar ist.

Abschluss bei schwerem Sicherheitsvorfall Innerhalb eines Monats nach der 72-Stunden-Meldung.

CRAwerk dokumentiert diese Schritte und Fristen. Die Anwendung sendet die Meldung nicht **selbst an die**

Behoerden oder ENISA.

B. Produkt oder Herstellerprozess ist nicht mehr konform

Wird eine Nichtkonformitaet erkannt, wird ein Vorgang angelegt. Dokumentiert werden

Beschreibung,

betroffene Version, Korrekturmassnahme und die Entscheidung, ob die Konformitaet

wiederhergestellt, das

Produkt vom Markt genommen oder zurueckgerufen wurde. Ein abgeschlossener Vorgang bleibt als Nachweis unveraenderbar.

C. Marktueberwachungsbehoerde fragt Unterlagen an

Bei einer begruendeten Anfrage werden Behörde, Aktenzeichen, verlangte Unterlagen, **gegebenenfalls die**

angeforderte SBOM, uebermittelte Informationen, Mitwirkungsmassnahmen und der

Uebermittlungsnachweis

dokumentiert. CRAwerk erfindet keine gesetzliche Antwortfrist, wenn die Behoerde keine nennt.

19. Beispiel: Verpackungsanlage VP-240

So koennte ein kompletter CRAwerk-Datensatz aussehen

**CRAwerk Handbuch fuer
Einsteiger****Fiktives Beispiel**

Die folgenden Angaben dienen nur als Lernbeispiel. Hersteller, Versionen und Dokumentnummern **sind frei**

erfunden und keine Produktempfehlung.

Grunddaten**Feld Beispiel**

Name Verpackungsanlage VP-240

Modell VP-240

Produktnummer VP240-2026-017

Verantwortlich Produktmanagement

Software/Firmware Ja

**Verbindung Ja - internes Ethernet, OPC UA zum Leitsystem,
Fernwartung ueber VPN-Gateway**

Software & Firmware

Eintrag Version / Hinweis

Steuerungsprogramm VP-240 Release 2.7.4

SPS Firmware 3.2.1

HMI Runtime 5.4.2

HMI Projekt VP-240 Release 2.7.4

Remote Gateway Firmware 4.8.1

Embedded Service Agent 1.6.0

Digitale Bauteile

Bauteil Hersteller/Typ Sicherheitsrelevanz

SPS Vendor A / PLC-500 Steuerung, Netzwerk, Firmware

HMI Vendor B / Panel-12 Bedienung, Nutzerkonten, Netzwerk

Remote Gateway Vendor C / RG-100 Fernwartungszugang und VPN

Vernetzter Antrieb Vendor D / Drive-X Feldbus, Firmware

Risiken**Risiko Bewertung Massnahme**

Gemeinsamer Service-Account fuer Hoch Personenbezogene Konten, MFA und

Fernwartung Rollen einfuehren.

**CRAwerk Handbuch
fuer Einsteiger**

Risiko Bewertung Massnahme

Unsigniertes USB-Update der Service- Hoch Signaturpruefung fuer

Updatepakete

Software aktivieren.

Unnoetiger Webdienst am HMI aktiv Mittel Dienst im Produktionsimage

deaktivieren.

Gateway-Support endet vor geplantem Mittel Austauschstrategie bzw.

kompatible

Maschinen-Support Ersatzkomponente

festlegen.

Konkretes Sicherheitsproblem**Feld Beispiel**

Bezeichnung Schwachstelle im Remote Gateway

Betroffen RG-100 Firmware 4.7.9

Schweregrad Hoch

Bewertung Fern erreichbare Verwaltungsfunktion kann

unter

bestimmten Bedingungen umgangen werden.

Massnahme Firmware auf 4.8.1 aktualisieren; Fernwartung bis dahin

nur ueber zusaetzliche Firewall-Regel.

Behoben am 20.09.2026

**Nachweis Security Advisory SA-2026-88,
Wartungsprotokoll
MP-240-77**

**Supportzeitraum
Feld Beispiel**

Beginn 01.01.2027

Ende 31.12.2034

**Begrueundung Erwartete Nutzungsdauer 8 Jahre; kritische
Kernkomponenten werden mindestens bis 2034**

unterstuetzt.

Beim Kauf sichtbar Angebot, Auftragsbestaetigung, Produktseite

**Endmitteilung HMI-Hinweis + Kundenportal + E-Mail an
registrierte
Betreiber**

CRA-Abschluss

- Produktklasse: Standardprodukt; Begrueundung dokumentiert.
- Konformitaetsweg: Modul A; Normenabdeckung und technische Loesungen dokumentiert.
- Alle 22 Schutzfragen bewertet und mit Begrueundung oder Nachweis versehen.
- Technische Dokumentation, Nutzerinformationen und Schwachstellenprozess vollstaendig.
- CE-Kennzeichnung angebracht; Ort auf Typenschild dokumentiert.
- EU-Konformitaetserklaerung unterzeichnet; DMS-Verweis hinterlegt.

**CRAwerk Handbuch
fuer Einsteiger**

20. Checkliste fuer den ersten Durchlauf

In dieser Reihenfolge ist CRAwerk am einfachsten

1. Unternehmensdaten vervollstaendigen: Firmenname, Anschrift, Land und Kontakt.

2. Maschine mit Name, Modell/Produktnummer und Verantwortlichem anlegen.
3. Software und Firmware mit realen Versionen erfassen. Unbekannte Versionen nicht erfinden.
4. Digitale Bauteile und Zulieferer erfassen, die Cybersecurity beeinflussen koennen.
5. Cyberrisiken durchgehen und konkrete Massnahmen mit Verantwortlichen anlegen.
6. Internen Ablauf fuer Sicherheitsprobleme und Updates festlegen.
7. Vorhandene Dokumente und Nachweise sauber referenzieren.
8. Supportzeitraum mit Begrueendung und Kundenkommunikation festlegen.
9. CRA-Abschluss oeffnen und mit Schritt 1 beginnen.
10. Die fuenf Schutzbloecke nacheinander bearbeiten; nicht alle 22 Fragen auf einmal.
11. Technische Beschreibung und Kundeninformationen ergaenzen.
12. CVD-Kontakt und Updateprozess vervollstaendigen.
13. CE und EU-Konformitaetserklaerung erst zum Abschluss als erledigt markieren.
14. Akte pruefen und offene Punkte abarbeiten.
15. SBOM, Nutzerinformationen, Kurzakten und Vollakte erzeugen und vor Freigabe fachlich pruefen.

Wenn Sie nicht weiterwissen

Tragen Sie keine erfundene Antwort ein. Lassen Sie den Punkt offen, holen Sie die technische **Information** beim Entwickler oder Zulieferer und dokumentieren Sie die belastbare Antwort spaeter.

21. Glossar

Kurz nachschlagen

Begriff Bedeutung

Angriffsfläche Alle erreichbaren Funktionen, Schnittstellen und **Wege, ueber** die ein Angreifer auf das Produkt einwirken koennte.

Authentifizierung Pruefung, wer ein Nutzer oder System ist, z. B. **Passwort**, Zertifikat oder MFA.

Autorisierung Festlegung, was ein angemeldeter Nutzer oder Dienst tun darf.

Bootloader Geraetenae Software, die beim Start Firmware oder

Betriebssystem laedt und oft Updatepruefungen durchfuehrt.

CVE Oeffentliche Kennung fuer eine bekannte

Schwachstelle.

CVD Geregelter Prozess fuer koordinierte Offenlegung von

Schwachstellen.

Firmware Geraetenae Software in einem Controller oder Embedded-

Geraet.

HMI Human Machine Interface, also Bedienoberflaeche einer

Maschine.

CRAwerk**Handbuch fuer Einsteiger****Begriff Bedeutung****Integritaet Sicherstellen, dass Daten oder Software nicht unbemerkt**

veraendert wurden.

MFA Multi-Faktor-Authentifizierung, z. B.

Passwort plus zweiter

Faktor.

Patch Aenderung, die einen Fehler oder eine

Schwachstelle behebt.

purl Standardisierte Package URL zur Identifikation eines Softwarepakets.**SBOM Maschinenlesbare Liste der Softwarekomponenten und**

Abhaengigkeiten.

Sicherheitsupdate Update, das eine Schwachstelle oder ein Sicherheitsrisiko

reduziert.

SPS / PLC Programmierbare Steuerung einer Maschine.

**Supportzeitraum Zeitraum, in dem der Hersteller
Schwachstellen behandelt**

und Sicherheitsupdates bereitstellt.

**Schwachstelle Konkrete Schwache, die ausgenutzt werden
kann.**

Vulnerability Disclosure Meldung und koordinierte Veroeffentlichung
von
Sicherheitsluecken.

22. Offizielle Quellen

Rechtsstand und weiterfuehrende Informationen

Dieses Handbuch basiert auf den folgenden offiziellen Quellen. Bei rechtlichen
Zweifelsfragen gilt der im
Amtsblatt veroeffentlichte Verordnungstext.

Quelle Adresse

[1] Verordnung (EU) 2024/2847 - Cyber Resilience Act
<https://eur-lex.europa.eu/eli/reg/2024/2847/oj/deu>

[2] EU-Kommission - Zusammenfassung des CRA
<https://digital-strategy.ec.europa.eu/de/policies/cra-summary>

[3] EU-Kommission - CRA-Umsetzung und Zeitplan
<https://digital-strategy.ec.europa.eu/de/factpages/cyber-resilience-act-implementation>

[4] EU-Kommission - FAQ zur CRA-Umsetzung, aktualisiert
[https://digital-strategy.ec.europa.eu/de/library/cyber-resilience-](https://digital-strategy.ec.europa.eu/de/library/cyber-resilience-act-implementation-frequently-asked-questions)
04.09.2026
act-implementation-frequently-asked-questions

[5] Durchfuehrungsverordnung (EU) 2025/2392 - technische
https://eur-lex.europa.eu/eli/reg_impl/2025/2392/oj/deu
Beschreibungen wichtiger und kritischer Produktkategorien

Pflegehinweis fuer CRAwerk

21

Recht, Leitlinien, Normen und technische Beschreibungen entwickeln sich weiter. Dieses **Handbuch sollte bei** relevanten Aenderungen versioniert und neu freigegeben werden. Auf jeder Ausgabe sollten **Version und Stand** sichtbar bleiben.